

# Account Lockout and Suspicious Authentication Procedure

COIT13236 | Security monitoring and incident response

SEC-05 | Version 1.0 | 9 September 2026

Owner: IT Administrator | Approval: \_\_\_\_\_ | Effective date: \_\_\_\_\_

Identify suspicious authentication and restore legitimate access without overlooking compromise. The IT Administrator applies this procedure to Samba AD, server logins and administrative access, using the account owner and service owner to verify activity.

Operating baseline: approve the proposed thresholds and response targets before activation. Review each semester and after a significant incident or system change.

## Monitoring and account policy

Collect validated success and failure events from Samba AD and relevant hosts. Samba supports authentication audit logging classes, including JSON audit output where supported by the build; verify the installed version, configuration and actual output before relying on it. Collect account and group changes using tested audit sources. [1]

Proposed lab account policy: lock an ordinary user account after 10 failed attempts within 15 minutes, with a 15 minute lockout. Confirm the effective domain policy and test it before use. Detection rules below are separate from account lockout; a detection must not automatically change domain policy. Review service-account dependencies and emergency access before activation.

| Proposed detection condition                                     | Initial severity                      |
|------------------------------------------------------------------|---------------------------------------|
| 5 failures for one account in 5 minutes                          | High                                  |
| Failures against 5 accounts from one source in 5 minutes         | High; possible password spraying      |
| 3 failures against a privileged account in 5 minutes             | High                                  |
| Success within 10 minutes after a High failure pattern           | High; investigate possible compromise |
| Single disabled-account attempt or unexpected out-of-hours login | Medium; validate context              |
| Confirmed privileged compromise or active misuse                 | Critical                              |

Correlate by account across sources to identify distributed attempts. An isolated password typo is Low. A lockout alone does not establish compromise. Approved hours and administrative source addresses must be recorded before anomaly rules are enabled.

## **Investigation and account recovery**

1. Acknowledge the alert under SEC-03, preserve the matching events and record the account, source host, authentication service, outcome, count and time window.
2. Check whether the account is locked, disabled, privileged or used by a service. Correlate successful logins, recent password changes, remote access, group membership and file activity.
3. Contact the account owner through a known independent channel. Check for stale saved credentials, scheduled tasks, mapped drives or an approved password change. Do not rely solely on a message from the potentially compromised account.
4. If compromise is suspected, restrict the affected account and source device, terminate active sessions or tickets where supported and assess downstream access. Password reset or disabling an account may not immediately end every existing session; verify containment.
5. For a service account, identify dependent services and coordinate credential rotation with the service owner. Preserve emergency administrative access. Record business impact, approver and rollback for disruptive action.
6. For a verified benign lockout, stop the source of repeated failures, verify identity, then unlock under approved policy. For compromise, remediate the endpoint, reset credentials through a secure channel, review privileges and re-enrol supported authentication factors as needed.
7. Test a valid login, a denied restricted-resource access and expected service operation. Monitor the account for at least 24 hours. Close after recurrence stops, the owner confirms access and the incident records root cause, evidence and follow-up actions.

## **Escalation and linked response**

Use SEC-01 for suspicious network activity, SEC-02 for affected files and SEC-04 for evidence. Promote immediately to Critical for confirmed privileged compromise. If the primary administrator account is affected, transfer response to the nominated backup using a verified clean account and device.

## Acceptance tests and policy register

### Controlled validation

| Test                                                          | Expected result                                                                  |
|---------------------------------------------------------------|----------------------------------------------------------------------------------|
| One wrong password on an ordinary test account                | Failure logged; no High alert from a single typo                                 |
| Five failures within five minutes                             | High notification reaches IT Administrator before the proposed lockout threshold |
| Ten failures within fifteen minutes                           | Effective lockout matches approved policy; valid login denied while locked       |
| Unlock or await expiry after fixing the failure source        | Valid test login succeeds and is recorded                                        |
| Failures across five disposable accounts from one test source | Password-spray correlation triggers                                              |
| Successful test login after a High failure pattern            | Follow-on success alert retains links to the earlier failures                    |

Use disposable accounts and scheduled lab tests. Do not deliberately lock the operational administrator or a live service account. Record observed policy, event times, notification receipt, expected and actual outcomes, evidence and tester. Restore test settings and verify normal authentication afterwards.

### Account policy register

Domain and authentication systems: \_\_\_\_\_  
Effective threshold / observation window / duration: \_\_\_\_\_  
Privileged accounts and approved source devices: \_\_\_\_\_  
Service accounts and dependency owners: \_\_\_\_\_  
Approved login hours and exceptions: \_\_\_\_\_  
Emergency access custodian and test date: \_\_\_\_\_

### Review

Review lockout trends weekly and privileged membership monthly. Tune detections only after documenting false positives and checking that attacks still trigger. Record rule owner, scope, approval, expiry and the date of the next test.

### References

[1] Samba Team. smb.conf manual. <https://www.samba.org/samba/docs/current/man-html/smb.conf.5.html> Accessed 9 September 2026.